
DOCUMENTO DE POLITICAS INTERNAS DE LA EMPRESA

HospITEC

Curso: CE-1115 Seguridad de la Información
Semestre: I Semestre 2026
Profesor: MSc. Andrés Vargas Rivera
Institución: Instituto Tecnológico de Costa Rica
Versión: 1.0
Fecha: Abril 2026
Clasificación: **Confidencial**
Integrantes: Ricardo Borbón Mena
Jorge Guillén Campos
Felipe Jiménez Ulate
Carlos Rodríguez Segura
José María Vindas Ortiz

Índice

1. Uso Aceptable del Sistema	2
2. Principios de Seguridad	2
3. Confidencialidad	2
4. Manejo de Datos Sensibles	3
5. Responsabilidades de los Usuarios	3
6. Uso de Dispositivos y Acceso	4
7. Gestión de Incidentes de Seguridad	4
8. Sanciones	4

1 Uso Aceptable del Sistema

El sistema de gestión de citas y cirugías está destinado exclusivamente para fines médicos, administrativos y operativos del hospital. Su uso debe alinearse con las siguientes disposiciones:

- Solo el personal autorizado podrá utilizar el sistema.
- Está prohibido el uso del sistema para fines personales, ilegales o no relacionados con las funciones laborales.
- Los usuarios deben ingresar información veraz, completa y actualizada.
- No se permite la manipulación indebida de datos, alteración de registros sin autorización o uso del sistema para perjudicar a terceros.
- El acceso al sistema debe realizarse mediante credenciales individuales, las cuales no deben ser compartidas.
- Se debe cerrar sesión al finalizar el uso, especialmente en equipos compartidos.

2 Principios de Seguridad

El acceso a la información médica de los pacientes es altamente sensible y estará restringido de la siguiente manera:

- Solo el personal directamente involucrado en la atención del paciente podrá acceder a sus datos.
- El acceso se otorgará según el rol del usuario (cirujano, anestesiólogo, asistente, etc.).
- Toda consulta, modificación o eliminación de datos queda registrada en el sistema mediante mecanismos de auditoría.
- Se prohíbe la copia o extracción de datos médicos sin autorización formal.
- El acceso remoto debe realizarse únicamente a través de conexiones seguras aprobadas por el hospital.

Estas políticas se implementan mediante controles técnicos en el sistema, incluyendo autenticación con 2FA, control de acceso basado en roles (RBAC), validaciones en el backend y registro de auditoría.

3 Confidencialidad

La información gestionada en el sistema es confidencial y debe ser protegida en todo momento siguiendo las siguientes reglas:

- Todo el personal debe firmar un acuerdo de confidencialidad antes de utilizar el sistema.
- Está prohibida la divulgación de información de pacientes a terceros no autorizados.
- La información solo puede ser compartida con fines médicos o legales debidamente justificados.
- El incumplimiento de las normas de confidencialidad puede derivar en sanciones disciplinarias o legales.
- Se deben aplicar buenas prácticas de seguridad, como el uso de contraseñas seguras y autenticación en dos factores (2FA).

4 Manejo de Datos Sensibles

Para garantizar el correcto funcionamiento del sistema, se establece la siguiente matriz de acceso para los roles definidos:

Sujeto/Objeto	Cirugías	Pacientes	Catálogos	Documentos	Usuarios
Paciente	R(Propias)	R(Propio)	-	R,W (Propios)	-
Cirujano	R,W	R	R	R	-
Anestesiólogo	R	R	R	R	-
Asistente	R,W	R	R	R	-

El acceso a la información se controla mediante mecanismos de autorización en el backend, asegurando que cada usuario solo pueda interactuar con los recursos permitidos según su rol.

5 Responsabilidades de los Usuarios

Todos los usuarios del sistema deben cumplir con las siguientes responsabilidades:

- Proteger sus credenciales de acceso y no compartirlas con terceros.
- Reportar cualquier actividad sospechosa o acceso no autorizado.
- No intentar evadir los controles de seguridad del sistema.
- Utilizar el sistema únicamente para fines autorizados.
- Cumplir con todas las políticas establecidas en este documento.

6 Uso de Dispositivos y Acceso

- El acceso al sistema debe realizarse desde dispositivos autorizados.
- No se debe acceder desde redes públicas no seguras sin protección adicional.
- Los dispositivos deben contar con medidas básicas de seguridad (bloqueo de pantalla, actualizaciones y protección contra malware).
- Se recomienda evitar el uso de dispositivos compartidos para acceder al sistema.

7 Gestión de Incidentes de Seguridad

En caso de detectarse un incidente de seguridad, se deben seguir los siguientes pasos:

- Reportar inmediatamente al administrador del sistema.
- Registrar el incidente en los sistemas de auditoría.
- Revocar accesos comprometidos.
- Analizar el origen del incidente y aplicar medidas correctivas.

8 Sanciones

El incumplimiento de las políticas establecidas en este documento puede resultar en:

- Suspensión temporal o permanente del acceso al sistema.
- Acciones disciplinarias internas.
- Posibles acciones legales en caso de violación de datos sensibles.